



Part—2

Last month, we started this series to cover the important cyber attacks that impact critical IT infrastructure in organisations. The first was the denial-of-service attack, which we discussed in detail. This month, we will cover the packet-spoofing attack, which is found to be a favourite among hackers, and widely used in exploiting network vulnerabilities. We will also discuss how this type of attack affects Linux systems, and how to mitigate the risks.

Spoofing, by definition, means to imitate or trick someone. To understand the spoofing attack, we need to examine the IP packet structure in detail. Many cyber attacks stem from design flaws in the fundamental network designs; packet spoofing is no exception. Please refer to Figure 1. As we know, a basic Ethernet network packet is essentially a data chunk with various pre-defined fields such as source and destination MAC addresses, frame checksum code, preambles, etc. In the case of the TCP/IP protocol, the TCP frame encapsulates the IP datagram, and both piggyback on the basic Ethernet packet. The TCP provides the connection-oriented information, while the IP packet contains source and destination addresses and ports. It is the duty of various OSI layers to contribute their bit towards the formation of a complete packet.

As we learnt last month, the TCP/IP works on a three-way handshake (SYN, SYN-ACK and ACK). This handshake establishes a connection between two different

network interface cards, which then use the packet sequencing and data acknowledgements to send or receive data. The conversation is formally concluded by using a FIN/FIN-ACK handshake. The source and IP address field values decide who is talking to whom, while the port fields decide which source application is talking to which destination application. IP address fields in the IP packet are filled up automatically by the upper layers; however, malicious users or programs can modify these fields—and this is exactly where the spoofing comes into the picture (refer to Figure 2). In a very simple packet-spoofing attack, the hacker creates IP packets targeting a destination, but the source IP field is modified so that it does not have the IP address of the hackers' computer, but in fact, of some other computer, which can be used as a data collector or a sniffer by the hackers. By its design, the TCP/IP stack running on the destination computer is supposed to respond to the source IP of the received